

Task 5: Malware Incidents Research

Malware 1: NonEuclid RAT

Description of Attack Method

- **Malware Type:** Remote access trojan with ransomware capabilities
- **Initial Vector:** Didn't find any Initial infection vector since the RAT is promoted in underground forums and social media platforms. It has gained traction due to features like stealth and is popular within cybercriminal communities.
- **Payload/Functionality:** Core Remote Access and Communication -> does Evasion and Anti-Analysis -> Persistence and Privilege Escalation -> Impact Actions (Ransomware and Data Collection[camera access])
- **Propagation/Lateral Movement:**
 - Initial Compromise/Installation Actions: Initialization/Evasion -> Anti-Process/Anti-VM Checks -> AntiScan (Defender Exclusions) -> UAC Bypass (Privilege Escalation)
 - Persistence Actions: Dropping Executable Files -> Creating Scheduled Tasks -> Updating HKEY_CURRENT_USER Registry Value
 - Operation/Impact Actions: Socket Communication (C2) -> Ransomware Encryption -> Camera Access
- **Targeted Systems/Data:** Victim's Computer -> Employs ransomware encryption on Critical Files -> Access multimedia devices(camera) -> terminate analyzing and managing processes(Taskmgr.exe, ProcessHacker.exe, and procexp.exe) -> modifies the Windows registry for persistence and UAC bypass

Mitigation and Resolution

- **Detection:** detected by cyfirma [<https://www.cyfirma.com/research/noneuclid-rat/>], does not explicitly said how they detected it
- **Containment:**
 - Deploy Endpoint Detection and Response (EDR) Solutions: To monitor endpoints for suspicious activities like unauthorized registry changes, process injections, and dynamic DLL loading, ensuring rapid containment.
 - Implement Strict Privilege Management: To enforce least-privilege access policies and ensure administrative actions are logged and monitored to prevent privilege escalation attempts by malware.
 - Perform Regular Patch Management and Audits: To ensure all systems, software, and frameworks are up to date with the latest security patches.

- **Eradication:**

- Perform Regular Patch Management and Audits: To ensure all systems, software, and frameworks are up to date with the latest security patches. This can address vulnerabilities that malware could exploit.
- Invest in Advanced Security Technologies: Specifically, memory-based scanning is mentioned as a capability of AI-driven tools that can help in detection and mitigation.
- Implement Strict Privilege Management: This would restrict the malware's ability to execute commands and maintain persistence.

- **Recovery:** I cannot find any recovery option but to reinstall os and restore data from backups

- **Lessons Learned/Prevention:**

- Strategic Recommendations: Enhance Threat Intelligence Sharing and Invest in Advanced Security Technologies
- Tactical Recommendations: Deploy EDR Solutions and Strengthen User Awareness Training
- Operational Recommendations: Implement Strict Privilege Management and Perform Regular Patch Management and Audits

- **Resources:**

- <https://vx-underground.org/Malware%20Analysis/2025/2025-01-02%20-%20NonEuclid%20RAT>
- <https://www.cyfirma.com/research/noneuclid-rat/>

Malware 2: Ave_Maria RAT

Description of Attack Method

- **Malware Type:** Remote access trojan also known as Warzone RAT
- **Initial Vector:** phishing emails with malicious attachments.
- **Payload/Functionality:**
 - Remote Access Trojan which allows full control over the infected device
 - Data Theft and Espionage(key logging -> credential theft -> extract stored passwords from web browsers -> web cam access -> file exfiltration)
 - System Manipulation and Evasion(Process Hollowing and Thread Execution Hijacking -> Reflective Code Loading -> Creates a Scheduled Task for persistence -> Establishes persistence by adding entries to the registry to run on user login -> Saves a copy of the JavaScript file to the Public folder -> exclude itself from Windows Defender -> grant full control permissions to Everyone for a specified target folder and all its contents -> Performs anti-analysis checks to check if it's on a VM)
 - Communication(Initializes URLs and downloads data from a remote server -> Uses C2 Communication:: Receive Data -> Uses HTTP Communication:: Get Response)
 - Code Execution(Decodes and loads a .NET assembly directly into memory -> invokes a method from the loaded assembly using obfuscated parameters -> it is a js file that eventually leads to a PowerShell code payload)
- **Propagation/Lateral Movement:** Initial Access -> First Stage Execution (JS) -> PowerShell Execution & Payload Retrieval -> Second Stage DLL/EXE Execution -> Primary Malicious Activity -> Persistence & Evasion
- **Targeted Systems/Data:**
 - Infected System Control: The malware aims for full control over an infected system.
 - Credentials/Passwords: It targets keylogging , credential theft , and the extraction of stored passwords from various web browsers and from Thunderbird and other SMTP and email-related services, including Outlook.
 - User Data: It targets file exfiltration and has the capability for webcam access.
 - Geographic Target: The sample was first uploaded from Greece and is most likely targeting organizations in that region.

Mitigation and Resolution

- **Detection:** detected by Bar Magnezi [0xMrMagnezi]
[<https://0xmrmagnezi.github.io/malware%20analysis/AveMaria/>], does not explicitly said how they detected it
- **Containment:**

- Seizing Malicious Domains: Authorities seized the internet domains (e.g., warzone.ws) that were used to market, sell, and host the Warzone RAT malware-as-a-service. This cut off the source of the malware for new cybercriminals.
- Disrupting C2 Infrastructure: International partners secured the servers that were hosting the RAT's Command-and-Control (C2) infrastructure worldwide. This prevents the existing infected RAT clients from receiving commands and exfiltrating data.
- Apprehending Key Actors: Individuals responsible for the development, sale, and customer support of the Warzone RAT were indicted and arrested in countries like Malta and Nigeria. This targets the human element of the criminal enterprise.
- Alerting Victims: The Indian Computer Emergency Response Team (CERT-In) released public alerts and established a dedicated reporting form (e.g., through IC3) to encourage victims to report compromise, thereby maximizing awareness and allowing for better tracking of the threat.

● **Eradication:**

- Antivirus/Anti-Malware Scan:
 - Run comprehensive, up-to-date security scans in Safe Mode to detect and quarantine the primary malicious executable
- Dismantling Persistence:
 - Registry Cleanup: Manually delete or use specialized tools to remove malicious entries the RAT created, particularly in Run Keys and the UAC Bypass keys (e.g., the hijacked COM key HKCU\Software\Classes\Folder\shell\open\command).
 - Defense Re-enablement: Reverse the PowerShell command used by the RAT to add its file path to the Windows Defender Exclusion List.
- Removing Malicious Artifacts:
 - Locate and delete any dropped files, batch scripts (program.bat), or malicious DLLs that the RAT used to download components or achieve process injection.
 - Clean up any WMI command-line entries or scheduled tasks used for automatic execution.
- Data and Access Remediation (Crucial):
 - Reset ALL Passwords and credentials that were stored on the infected machine, as the RAT is a keylogger and info-stealer.
 - Disable and Delete any rogue user accounts the attacker might have created for persistence.
- System Integrity:
 - Patch Vulnerabilities: Ensure the operating system and all software (especially Microsoft Office/Equation Editor for CVE-2017-11882) are fully patched to prevent immediate re-infection.
 - Consider System Rebuild (Best Practice): For critical systems or cases involving the premium "Poison" variant (which can use a rootkit), the

safest measure is a full format and clean reinstall of the operating system.

● Recovery:

- Data Restoration (from a Clean State):
 - Restore from Backup: Restore data and critical files from secure, segregated backups taken before the date of the known infection.
 - Verify Integrity: Ensure the restored systems and files are clean and fully functional before reconnecting them to the main network.
- Identity and Access Management Remediation:
 - Force Credential Rotation: Reset all passwords for all users, administrators, and services that had credentials present on the infected machine.
 - Invalidate Sessions: Terminate all active web sessions and revoke all current authentication tokens (especially for cloud services and email) to cut off the attacker's established access.
 - Multi-Factor Authentication (MFA): Mandate and enforce MFA on all critical accounts to prevent account takeover even with stolen passwords.
- System Reconfiguration & Hardening:
 - Audit and Reconfigure: Review system configurations, firewall rules, and network segmentation to ensure the attacker did not leave behind any backdoors or new accounts.
 - Implement Application Control: Restrict the execution of unauthorized programs to prevent re-infection via simple executables.
- Post-Incident Analysis and Reporting (India Specific):
 - Forensic Documentation: Complete a detailed forensic report documenting the breach timeline, data accessed, and steps taken for eradication.
 - Regulatory Reporting: Report the cybersecurity incident, including details of the data breach and unauthorized access, to the Indian Computer Emergency Response Team (CERT-In) within the mandatory six-hour window.
- Lessons Learned:
 - Conduct a review to identify the specific weak link (e.g., lack of patching, poor phishing awareness) that allowed the RAT in.
 - Update Employee Awareness Training to specifically warn against phishing emails that trick users into downloading attachments that drop the RAT.

● Resources:

- <https://vx-underground.org/Malware%20Analysis/2025/2025-05-15%20-%20Ave%20Maria%20Malware%20Analysis>
- <https://0xmrmagnezi.github.io/malware%20analysis/AveMaria/>

Malware 3: I2PRAT

Description of Attack Method

- **Malware Type:** Multi-stage Remote Access Trojan (RAT)
- **Initial Vector:** through a ClickFix campaign
- **Payload/Functionality:**
 - Privilege Escalation: The loader attempts to elevate privileges to NT Authority\SYSTEM by abusing an RPC mechanism or by migrating its process into an elevated system process.
 - Defense Evasion: It runs a PowerShell script to disable Windows Defender options (like sample submission and MAPS reporting) and adds an exclusion path for its dropped files. It also drops a utility to block outbound traffic to security-related services.
 - Persistence: It creates an autostart service named "RDP-Controller".
 - C2 Communication: It communicates with its Command and Control (C2) server over an encrypted TCP connection using the I2P anonymization network
 - RAT Operations: It uses multiple DLL modules to execute commands from the C2, including managing files (upload/download/delete), managing user accounts, collecting host information, and managing RDP configuration and exposure
- **Propagation/Lateral Movement:**
 - Privilege Elevation: Elevates to NT Authority\SYSTEM
 - Remote Access: The rdpcctl.dll module manages the RDP configuration and exposure of the infected host.
- **Targeted Systems/Data:** Windows based devices
 - Host and Configuration Data: Collects host fingerprint (OS version, build, username) , memory status, network setup, and installed web browsers.
 - File System: Manages (deletes, uploads, downloads) files on the infected host.
 - User Accounts: Manages user accounts (get, update, create, delete).
 - Remote Access: Manipulates RDP configuration and exposure.
 - Privileges: Seeks to gain NT Authority\SYSTEM and local admin privileges.

Mitigation and Resolution

- **Detection:**
 - Monitoring a known technique: The TDR team was monitoring a technique known as ClickFix.

- Undocumented Payload: A payload dropped in a campaign starting from November 2024 drew attention because of the absence of a signature and the lack of documented behavior and network patterns in public reports.

- **Containment:**

- Isolate Infected Systems:
 - Quarantine: Immediately isolate the infected endpoint using EDR tools or Network Access Control (NAC).
 - Physical Disconnect: If automation fails, physically disconnect the network cable.
 - Account Lockout: Disable or reset credentials for any compromised user or service accounts.
- Block I2P Communication:
 - Firewall Rules: Block the common UDP/TCP ports used by the I2P network on perimeter and internal firewalls.
 - Signature Blocking: Deploy new I2PRAT-specific signatures to IDS/IPS systems to identify and block the malware's encrypted C2 traffic.
 - Remove Components: Locate and remove the installed I2P client files (like DLLs or executables) to permanently sever the C2 channel.

- **Eradication:**

- System Reimage: The most secure step is to wipe the hard drive and reinstall the Operating System from a clean source to ensure all backdoors and root-level changes are gone.
- Targeted Removal: If re-imaging is not feasible, perform aggressive offline anti-malware scans to find and delete the core RAT files and the associated I2P client components (e.g., DLLs).
- Remove Persistence: Manually delete malicious startup entries, services, and unauthorized accounts created by the RAT.
- Credential Reset: Mass-reset all affected user passwords and enforce Multi-Factor Authentication (MFA) immediately, as the RAT likely stole credentials.
- Patching: Patch the original vulnerability (e.g., application exploit, system flaw) that allowed the infection to occur.

- **Recovery:**

- Data Restoration: Restore critical files and configurations from verified, clean backups (taken before the infection).
- System Reintegration: Phased reintegration of rebuilt (clean) systems into the network, prioritized by business necessity.
- Final Security Reset: Mandatory rotation of all privileged credentials and final deployment of security patches to the vulnerability that was exploited.
- Verification: Implement enhanced monitoring to ensure the restored environment shows no signs of lingering malware or C2 activity.
- Functional Testing: Business teams verify system and application functionality before full operational status is declared.

● **Resources:**

- <https://vx-underground.org/Malware%20Analysis/2025/2025-02-11%20-%20RATatouille%20-%20Cooking%20Up%20Chaos%20in%20the%20I2P%20Kitchen>
- <https://blog.sekoia.io/ratatouille-cooking-up-chaos-in-the-i2p-kitchen/>